NETWORKING

# DNS Security Visual Guide

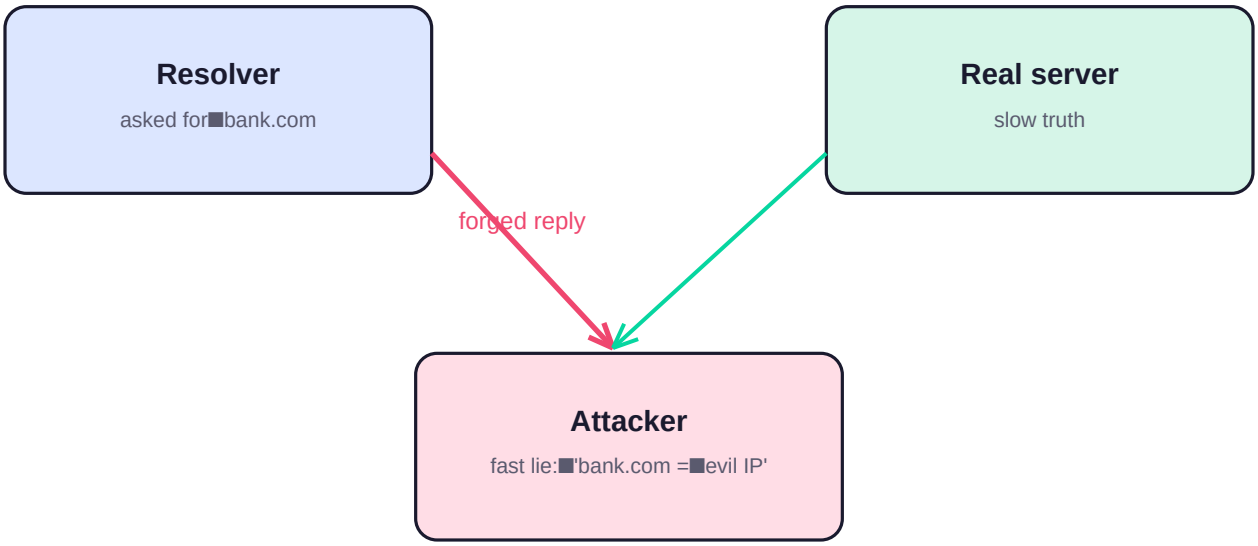
Trusting names —
poisoning, DNSSEC, and encrypted DNS.

**ANIMATED WALKTHROUGH**
Step through pages to play the animation

STEP 1/5

# Cache Poisoning: The Attack

Race the real answer — whoever replies first wins the cache.



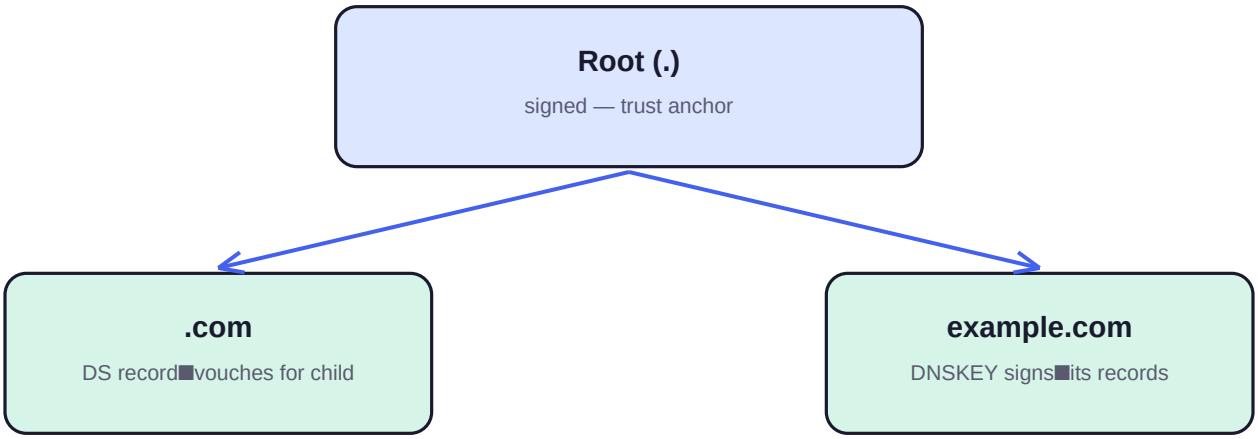

- Classic DNS runs over UDP with a 16-bit query ID — guessable, spoofable, first-reply-wins.
- Poisoned cache redirects EVERY client of that resolver until the TTL expires.
- Kaminsky (2008) made it devastating: poison the NS records, own the whole domain.

  Source-port randomization was the emergency fix.

STEP 2/5

# DNSSEC: Chain of Trust

Cryptographic signatures from the root down — tampering is detectable.




- Each zone signs its records (RRSIG); the parent publishes a DS hash of the child's key — a chain to the root.
- Validators reject forged answers — poisoning becomes cryptographically infeasible.
- Limits: DNSSEC signs but doesn't ENCRYPT (queries still visible); deployment is still partial.

STEP 3/5

# DoT & DoH: Encrypted DNS

Hide queries from snoopers on the path.

**DoT (port 853)**

DNS over TLS■dedicated port■easy to identify■& block

**DoH (port 443)**

DNS over HTTPS■blends with web■traffic■hard to block

- Both encrypt queries between stub resolver and recursive resolver — ISPs and Wi-Fi snoopers go blind.
- Trust shifts: your DoH provider (Cloudflare, Google, Quad9) now sees all your queries — choose deliberately.
- Enterprise tension: encrypted DNS bypasses local filtering/monitoring — split-horizon and policy configs answer it.

STEP 4/5

# Response Validation Checklist

What a careful resolver verifies.

### Bailiwick check

is this server AUTHORITATIVE for the answer? Out-of-bailiwick data gets dropped.

### DNSSEC validation

signature chain verifies against the trust anchor?

### 0x20 randomization

mixed-case query echoed exactly — cheap spoofing tripwire.

### Response sanity

reply matches query ID, port, and question section.

STEP 5/5

# Defense in Depth for DNS

No single fix — layer them.

- Run a validating resolver (Unbound, BIND) with DNSSEC on — validate everything you can.
- Use DoT/DoH to a provider you trust; keep a fallback for captive portals.
- Short TTLs on critical records limit poisoning blast radius (at a caching cost).
- Monitor: unexpected record changes and DNS tunneling patterns in query logs.
- Register defensively: lock transfers (AXFR), DNSSEC-sign your own zones, monitor CT logs for lookalike domains.

DNS is plaintext metadata about everything you do online — treat its privacy and integrity as first-class requirements.

STEP ✓/✓

# Key Takeaways

## DNS Security — Remember

- Cache poisoning races forged UDP replies into resolvers — first reply wins.
- DNSSEC builds a signature chain from the root: tampering becomes detectable.
- DoT (port 853) and DoH (port 443) encrypt queries — trust shifts to your provider.
- Resolvers validate: bailiwick, DNSSEC, 0x20 case, query/port matching.
- Layer defenses: validating resolver + encrypted transport + signed zones + monitoring.

**Keep exploring**

Pair this guide with the matching video walkthroughs
and hands-on labs at interstitiumlabs.dev